Whiteout AI

BY:

GROOVY SECURITY

SECURITY WHITEPAPER

Enterprise AI Security & Compliance

How Whiteout AI enables organizations to safely adopt generative AI — real-time semantic policy enforcement with 96.8% corrected accuracy, coverage across browser, desktop, IDE, infrastructure, mobile and MCP, prompt-injection defense for agentic tools, and a complete, exportable audit trail.

Version 4.5 · October 2026

Whiteout AI — an AI governance & security platform by **Groovy Security** · groovysec.com

Contents

Whiteout AI — Enterprise AI Security & Compliance Whitepaper

Executive Summary . . . 3

The Enterprise AI Governance Challenge . . . 3

Platform Architecture . . . 4

The Compliance Engine . . . 5

The Block Workflow: Redaction & Accountable Override . . . 6

Group-Based Policy: Full Customizable Control . . . 7

Benchmark & Validated Accuracy . . . 8

Coverage: Everywhere Employees Touch AI . . . 10

Prompt-Injection Defense & Agentic AI Security . . . 12

MCP Governance: One Governed Front Door to Corporate Data . . . 13

Identity, Access & Device Trust . . . 15

Audit, Visibility & SOC Integration . . . 16

Deployment, Operations & Platform Security . . . 17

Regulatory Alignment . . . 17

Conclusion . . . 18

Executive Summary

Generative AI has become the fastest-adopted workplace technology in history — and the fastest-growing data-exfiltration channel. Employees paste customer records into chatbots, attach contracts to AI assistants, wire coding agents into production repositories, and authorize AI connectors against corporate document stores. Traditional security tooling — file-oriented DLP, CASB blocking, security-awareness training — was never designed for conversational, agentic AI, and it shows.

Whiteout AI, by Groovy Security, is an enterprise AI governance and security platform that closes this gap. It evaluates AI interactions — prompts, file uploads, pastes, tool calls, and connector reads — against your organization's policies, stopping sensitive data **before** it reaches an external AI service wherever the surface allows a pre-send check, and recording it everywhere else. Its coverage now spans more of the places employees touch AI than ever before: the browser, native desktop apps, IDEs and coding agents, server-side workloads and SDKs, the MCP connectors that wire AI assistants into business systems, and managed mobile devices.

The platform's verdicts come from a dedicated semantic compliance engine — a full open-weights LLM, self-hosted inside your deployment boundary and never a third-party model provider — governed by 54 expert-authored policies across 8 regulated data classes, every one of them enabled **group by group**, so each department gets exactly the guardrails its work requires. On the public 100,000-prompt Whiteout AI Compliance Benchmark, the deployed engine achieves **96.8% corrected accuracy** with a **99.9% pass rate on everyday prompts**, sub-two-second median verdicts, and a complete, exportable audit trail of every decision.

Platform at a glance

54	Expert-authored policies across **8** regulated data classes
96.8%	Corrected compliance-engine accuracy on the public 100,000-prompt benchmark (96.53% raw)
99.9%	Pass rate on everyday work prompts — 40 false blocks in 36,416
40+	AI assistants and model providers governed
7	Governed surfaces — browser, desktop, IDE, infrastructure, SDK, MCP connector, mobile — enforcing before send where the platform allows it, auditing where it doesn't
23	Governed data-source integrations behind one AI connector
9	SSO / identity providers · **SCIM 2.0** provisioning · **6** SOC/SIEM destination types
~1.1 s	Median verdict for an allowed prompt on the benchmark run · ~0.03 s on cached verdicts

The Enterprise AI Governance Challenge

Generative AI creates a new category of risk: **conversational data exfiltration**. Sensitive information leaves the organization not as files crossing a boundary, but as natural-language context typed, pasted, and attached into AI tools — and increasingly, as documents that AI agents *pull for themselves* through connectors and tool calls.

Four risks every enterprise now carries

- **Data breach liability.** Information shared with external AI services may be stored, used for training, or exposed. A single pasted patient chart or customer export can constitute a reportable breach.
- **Regulatory violations.** HIPAA, GDPR, PCI-DSS, SOX, and FERPA all restrict sharing regulated data with unauthorized third parties. AI assistants are third parties.
- **Intellectual-property loss.** Source code, algorithms, and trade secrets shared with AI services may lose legal protection — and may surface in someone else's completions.
- **Competitive exposure.** Strategic plans, M&A details, and unreleased financials pasted into consumer AI tools are outside your control the moment they are sent.

Why existing controls fall short

- **DLP falls short.** File- and pattern-oriented Data Loss Prevention cannot analyze unstructured conversational context. "Summarize the treatment plan for the patient in this note" defeats a regex.
- **CASB creates crisis.** Blocking AI services outright pushes usage to personal devices and personal accounts — zero visibility, zero governance, and the productivity gain your competitors keep.
- **Training isn't enough.** Employees have good intentions but cannot reliably identify every category of regulated data in real time, under deadline, in a chat box.

The new frontier: agentic AI

The risk surface is no longer just a chat window. Coding agents execute shell commands and edit repositories. AI assistants connect to Google Drive, Jira, and Slack through MCP (Model Context Protocol) and vendor connectors, reading corporate data at machine speed. Tool outputs can carry **prompt-injection payloads** that redirect an agent against its own organization. Governing modern AI means governing prompts, files, tool calls, connector reads, and agent behavior — together.

Platform Architecture

Whiteout AI is built on one architectural principle: **distributed enforcement, authoritative core**.

Lightweight enforcement runs at every endpoint for instant local checks — provider blocklists, model allowlists, rate limits, and injection-pattern scanning. Every surface then forwards to a single central backend that owns the **authoritative policy verdict**, the **audit record**, and **SOC/SIEM delivery**. One policy library, one decision engine, one system of record — no matter where the interaction happened.

1. **Interface detection** — the surface recognizes an AI tool (a web app, a desktop app, an IDE agent, an API call, a connector read).
2. **Event interception** — the send, upload, paste, drop, or tool call is held before any data leaves.
3. **Content extraction** — prompt text, file contents (with OCR), or tool-call payloads are extracted.
4. **Compliance evaluation** — the compliance engine evaluates the content against the policies enabled for that user's group.
5. **Conditional release** — the original action proceeds only if compliant; otherwise the user gets a block with the policy reason, an optional sanitized rewrite, and (where enabled) an accountable override path.

Data residency by design

The authoritative judge is a **self-hosted model served on your own infrastructure** (an OpenAI-compatible inference server, schema-constrained JSON output, temperature 0 for reproducible verdicts). Customers in healthcare, finance, legal, and government can check whether content is safe to send to external AI **without sending that content to external AI**. There is no vendor-LLM fallback: compliance checks are never sent to an external AI provider.

Direction-aware policy

Every policy independently targets **internal** AI (your self-hosted or first-party models) and **external** AI (public SaaS assistants). The same patient record can be allowed into a governed internal model and blocked from leaving to a consumer chatbot — one policy library, two enforcement postures: productivity inside, protection outbound.

An honest enforcement posture

Whiteout AI is engineered availability-first and states its trust model plainly. Endpoint enforcement **fails open by design**: if the backend is briefly unreachable, employees keep working and the event is logged — a governance product that bricks workflows gets uninstalled. Hard guarantees come from the layers designed for them: **MDM-driven deployment** (force-installed extensions, zero-touch enrollment, hardware-anchored device identity), **tamper-resistant components** with integrity monitoring and automatic repair, and **coverage dashboards** that make any gap — a disabled extension, a dark agent, an unmanaged device — immediately visible to administrators. Availability behavior is also configurable: regulated organizations can flip a per-organization setting to **fail closed** when the engine is unreachable.

The Compliance Engine

Unlike traditional DLP that relies on pattern matching, the Whiteout compliance engine uses a full LLM to understand the **semantic meaning and context** of every interaction.

Context matters

Verdict	Prompt
BLOCKED	"*Summarize the treatment plan for patient John A. Murphy, DOB 03/12/1974, MRN 4583921. He was diagnosed with Type 2 Diabetes last month, his most recent HbA1c was 8.9%, and he has been prescribed Metformin 1000mg twice daily…*"
ALLOWED	"*I have a patient I need help with — help me build a reusable treatment plan summary template I can use.*"

Pattern matching flags both prompts (or neither). Whiteout AI understands that the first contains real patient identifiers and protected health information, while the second is a generic template request with no sensitive data. This distinction — drawn correctly across every prompt an organization sends — is the difference between governance employees accept and governance they route around.

Engine properties

- **Explainable verdicts.** Every evaluation returns `COMPLIANT` / `NON-COMPLIANT`, a human-readable reason, and the exact policy IDs that fired, each with a per-rule severity score. Decisions are auditable and tied to a specific rule — never an opaque score.
- **Admin-authoritative enforcement.** The engine is a rule enforcer, not a general safety filter: it evaluates what content *contains*, not what it asks, and only rules an administrator enabled for that group can fire. When a data class is disabled, it produces **zero enforcement on it** — 0 hallucinated blocks across 372 disabled-rule probes in testing.
- **Graduated enforcement actions.** From any block: **Allow** (compliant), **Block** (with reason), **Redact** (sanitized rewrite), or **Accountable Override**. The Infrastructure Agent adds fleet-wide **enforce / warn / monitor** modes for progressive rollout.
- **Verdict caching.** Successful verdicts are cached against prompt, context, and a hash of the current policy state — repeat submissions return in ~30 ms, and any policy edit invalidates the cache instantly. Error verdicts are never cached.

Large documents and files

Uploads return a scan handle in ~100 ms while a background pipeline extracts, chunks, and evaluates — with live progress and a terminal allowed / blocked / partial verdict. Extraction covers PDFs, Office documents, images (OCR), CSV, HTML, JSON/YAML, XML, OpenDocument, and archives. Content is split into overlapping chunks evaluated concurrently, and the first violating chunk short-circuits the job. Sensitive data on page 40 of a contract is found on page 40 of the contract.

Availability, your call

A per-organization setting decides whether a brief engine outage **allows with an amber warning** (default) or **hard-blocks** until the engine returns. A dedicated **Audit-Only / Discovery tier** runs the entire platform in observe-and-log mode — the deployment pattern for discovering shadow-AI exposure before turning on enforcement.

The Block Workflow: Redaction & Accountable Override

Enforcement that dead-ends gets circumvented — screenshots, personal devices, shadow accounts. Enforcement that offers a governed path forward gets adopted. When Whiteout AI blocks a prompt or file, the employee is never stranded, and every path forward preserves accountability.

What the employee experiences

1. **The send is held.** The composer locks for the ~2 seconds the verdict takes; compliant prompts release with no interruption at all.
2. **A clear block card** names the exact policy that fired and explains the reason in plain language. Every block doubles as training: employees learn *what* made the content sensitive, not just that something did.
3. **Governed paths forward** — revise the prompt; insert the sanitized rewrite; or, where their group allows it, take an accountable override. Every choice is logged.

The redactor: a sanitized rewrite, one click away

- The block verdict returns **immediately**; the rewrite is generated on demand — no spinner while the user decides what to do.
- Sensitive values are replaced with **descriptive placeholders**, so the question survives while the data doesn't — the prompt keeps its meaning and its usefulness.
- One click inserts the rewrite back into the composer. In native desktop apps, Desktop Guard writes it into the application's own input field and **verifies the text actually landed**, falling back to the clipboard so work is never lost.
- **It refuses rather than mangles.** A rewrite that would strip away most of the prompt is declined with an honest explanation (too sensitive to sanitize / nothing to change / temporarily unavailable) instead of returning garbage.
- **It never blocks its own fix.** The rewrite carries a single-use, five-minute approval bound to a hash of the exact sanitized text — resubmitting it passes without re-evaluation, and any edit voids the approval and triggers a fresh scan.

Accountable Override: a governed release valve

Where an administrator enables it **for a group**, a member of that group can release a specific blocked item — by putting their name on it.

The workflow when selected for a group:

1. The block card offers **Override** alongside the rewrite option (groups without the grant never see it).
2. The user writes a **justification** — a server-enforced minimum, not an empty ritual.
3. **The server is the sole authority.** It re-verifies the original block, the group's override permission, and the user's current membership — a client cannot self-authorize, and the compliance engine is never re-run or weakened.
4. A **single-use token** is minted: five-minute lifetime, bound to the SHA-256 of the exact content. Exactly what was justified is released, exactly once — an edited resend fails safe to a fresh block.
5. **The record is permanent.** The original audit row is marked overridden with who, when, and why; a distinct `prompt_overridden` event streams to every configured SOC destination; the override is counted on the executive dashboard and reviewable — justification included — in Prompt Review.

The same gate serves all four enforcement surfaces (browser, desktop, file uploads, IDE). The policy still fired; the record shows it; a named person took responsibility. Hard blocks with no escape hatch get worked around, and blanket bypasses destroy the audit trail — this is the governed middle: work keeps moving, and compliance gets a defensible record of every exception.

Group-Based Policy: Full Customizable Control

Real organizations are not uniform — legal, engineering, finance, and HR carry different data, different regulations, and different risk appetites. Every enforcement decision in Whiteout AI is therefore scoped to **groups**, synced from your identity provider, so policy mirrors the org chart instead of flattening it:

- **Per-group policy toggles** — each of the 54 library rules is enabled or disabled per group, each with its own independent internal/external direction. Engineering gets source-code and secrets policies without clinical-data noise; clinical teams get PHI enforcement without code-IP friction.
- **Per-group custom rules** — free-text rules (a project codename, a customer list, an internal hostname) merge into the same semantic evaluation, per group, with the same direction controls.

- **Per-group override rights** — Accountable Override is a group-level grant: give the deal desk a governed release valve while keeping a hard boundary for interns.
- **Per-group data exposure** — which integrations are exposed to AI is decided per group and per integration, and connector policies carry group exemption carve-outs: Finance may retrieve finance documents through the AI connector while every other group stays blocked.
- **Groups follow the IdP** — membership, renames, and lifecycle sync from Entra, Okta, and the rest, so enforcement scope updates when HR updates the directory — not when someone remembers to edit a console.
- **Group-scoped visibility** — the executive dashboard, analytics, and reports all re-scope by group, so each department's posture is measurable on its own terms.

The result: one platform, one audit trail — and per-department guardrails precise enough that no team is ever asked to live under another team's policy.

Benchmark & Validated Accuracy

Most governance vendors publish adjectives. Whiteout AI publishes a benchmark.

The public benchmark

The **Whiteout AI Compliance Benchmark** is a 100,000-prompt evaluation corpus across all eight policy domains — PII, PHI, GDPR, Legal, Code, Confidential, Security, and Finance — in six bands: **core** violations, safe prompts, and edge cases (36,095); **benign** everyday work prompts that must pass (36,416); **mixed** requests that pair a real task with sensitive or masked content (9,920); **multilingual** prompts across six languages (7,548); **adversarial** prompts using thirteen obfuscation techniques (6,673); and **long** documents of 1,000 to 7,800 characters with buried and split payloads (3,348). Every prompt carries a ground-truth verdict and the policy facet it exercises. The dataset is **published on Hugging Face** (`ShmalexFlow/enterprise-ai-prompt-compliance-100k`) under Apache 2.0, so customers and researchers can verify every number below themselves.

How the number is scored — and why we report the stricter one

Raw accuracy is easy to compute and easy to inflate. Whiteout AI publishes **corrected accuracy**: after a run, every residual miss is checked against the written text of the deployed policy that governs it. If the rule's own wording disagrees with the corpus label, the label is wrong and the score is adjusted; if the rule agrees with the label, the engine is wrong and nothing is adjusted. Crediting an engine defect as a bad label would inflate the headline by exactly the work still owed, so we do not. Eight independent readers adjudicated a random sample of misses under that standard; the correction is reported with a 95% confidence interval.

Result — deployed engine, September 2026	Value
Corrected accuracy	**96.78%** (95% CI 96.65–96.95)
Raw accuracy	96.53% on 99,959 scored prompts
Violations blocked (recall)	96.43%
Pass-expected prompts allowed (specificity)	96.59%
Everyday prompts allowed	**99.89%** — 40 false blocks in 36,416
Prompts that fell through to fail-open	**0** of 100,000

The per-class pattern

Data class	Prompts	Accuracy
PHI	15,031	97.94%
Security	11,322	97.77%
Finance	9,256	97.23%
Legal	10,978	96.73%
Code	12,153	96.64%
GDPR	11,909	96.60%
PII	16,701	96.43%
Confidential	12,609	93.01%

On **canonical regulated-data fingerprints** — card numbers, SSNs, IBANs, medical record numbers, credentials — the engine rarely slips. The residual error mass is **judgment-shaped**: violations of meaning rather than of token (roadmaps, board minutes, incident narratives) and over-caution on masked or placeholder values. Those are documented, sized, and on the fine-tuning roadmap in the technical report; none of them are label errors we have credited ourselves for.

Why the everyday pass rate is the headline

A governance tool that cries wolf gets disabled. Forty false blocks across 36,416 everyday work prompts — a 99.89% pass rate on the traffic that actually fills an employee's day — means Whiteout essentially **never interrupts legitimate work**. That property, more than any accuracy decimal, is what makes enterprise-wide enforcement politically deployable.

Speed

Speed is measured on the same run as accuracy, not in a separate demo.

Path	Median	What the user experiences
Approved / clean pass-through	~1.1 s	Prompt clears; no interruption
Blocked — verdict, cited rules, and sanitized rewrite	~2.7 s	Block shown with the safe rewrite ready
Sustained throughput	9.6 prompts/s on two engines	100,000 prompts in under three hours

Verdicts are produced in direct mode with schema-constrained decoding, so the model never spends time reasoning out loud; only about 3% of prompts — an allowed verdict on content that carries a detected identifier or a semantic-risk signal, or a block the engine itself attributes to masked content — take a second, fully reasoned look.

Fail-closed by design

A verdict the engine cannot finish or cannot express is **held**, never allowed: the user sees a "compliance incomplete" reason instead of a silent pass. The 100,000-prompt run surfaced one path that violated this rule, and it was closed and re-verified: 0 of 100,000 prompts now fall through to fail-open. When an administrator switches an identifier-class policy off, a deterministic guard stops the engine from blocking that content under a neighbouring rule; for semantic policies this remains an open item. The full validation, including its current limits, is in the technical report.

The complete methodology, per-band and per-category tables, latency distributions, error analysis, and roadmap are in the **Whiteout AI Compliance Benchmark — Technical Report TR-2026-09**.

Coverage: Everywhere Employees Touch AI

Governance with gaps is theater. Whiteout AI governs seven surfaces so that policy follows the employee — not the other way around. Each one enforces before send where the platform allows it and audits where it doesn't, and each section below says which.

Browser Extension

A Manifest V3 extension for **Chrome, Edge, Firefox, and Safari** from a single codebase — real-time DLP for AI web apps and for the AI embedded inside office suites.

- **Standalone AI web apps:** ChatGPT · Claude · Google Gemini · Microsoft Copilot · Perplexity · Mistral · Grok · DeepSeek · You.com · Poe · HuggingFace Chat
- **Embedded Microsoft 365 Copilot** (the app stays usable; only the AI is governed): Excel · Word · PowerPoint · Outlook · Teams · M365 Copilot Chat · SharePoint
- **Embedded Google Workspace Gemini:** Gmail · Docs · Sheets · Slides · Drive · Chat
- **Real-time prompt interception** — capture-phase send gating locks the composer until the verdict returns; an explicit "allowed" triggers the real send, and the interceptors re-attach as AI sites re-render.
- **File, paste & drag-drop interception** — uploads are scanned before they attach; large pastes that sites silently convert into attachments (a known scanning bypass) are wrapped and scanned as files.
- **Connector & OAuth-grant blocking** — admin-blocked connector rows inside ChatGPT, Claude, and Gemini are disabled at the UI, and connector OAuth grants are stopped **before any token is minted**, with a network-layer backstop for server-side redirects. Plain "Sign in with Google" is never disrupted.
- **Full and surgical app blocking** — block a disallowed AI app entirely, or disable just the embedded AI inside an otherwise-allowed Office/Workspace host.

Desktop Guard

A native endpoint guard with feature parity across **Windows** and **macOS**, governing the desktop AI apps that never touch a browser. It is also the device's identity broker and the owner of the prompt-injection defender hooks.

- **Watched apps:** ChatGPT Desktop · Claude Desktop · Claude for Chrome · OpenAI Codex · Microsoft Copilot · Microsoft 365 Copilot · Office Copilot in Excel/Word/PowerPoint/Outlook/Teams · Perplexity Desktop · Gemini Desktop
- **Pre-send prompt gate** — a system-level keyboard tap holds Enter in a watched app, extracts the composer text via the OS accessibility layer, scans it, and re-synthesizes the send only if allowed.
- **Large-paste DLP** — clipboard text over the attachment-conversion threshold is scanned *before* paste, closing the "PASTED as attachment" bypass.
- **File-drop overlay & guarded attach** — dropped files are scanned before they attach, every attach-menu path routes through a guarded picker, and after a pass the attachment chip is verified in the app's accessibility tree — because field testing proved synthetic attaches can silently fail.
- **Org-blocked app lockdown** — banned apps get a full-screen "blocked by your organization" overlay with keystrokes swallowed.
- **Network egress observation** — metadata-only, observe-only capture of AI-provider traffic (macOS Network Extension; Windows ETW service) that never blocks traffic and never fights the EDR — catching AI usage even from tools without a watcher.
- **Tamper-resistant presence** — a live status tray with no casual quit path; exit routes through a control panel that can enforce an organization logout password.

IDE Plugins & AI Coding Assistants

Coverage across the **VS Code family** (VS Code, Cursor, Windsurf) and the **JetBrains** IDEs (IntelliJ, PyCharm, WebStorm, GoLand, DataGrip, and more), published on both marketplaces.

- **Assistants covered:** Claude Code · GitHub Copilot · OpenAI Codex · Cursor built-in AI · Windsurf · VS Code built-in Chat (native agent mode) · Gemini CLI · Aider · terminal AI CLIs
- **Intercept** — a `@whiteout` chat participant provides an opt-in pre-send policy gate for Copilot Chat and Codex; transparent pre-send enforcement for Claude Code, Cursor, and OpenAI Codex is delivered by managed defender hooks (next section).
- **Audit** — post-hoc transcript monitoring for Claude Code, Codex, Cursor, VS Code's built-in chat/agent sessions, Gemini CLI, Aider, and terminal AI usage, from the artifacts these tools already write — including injection scanning of the AI instruction files agent modes generate and auto-inject (`AGENTS.md` , `.github/copilot-instructions.md`).
- **Detect** — enumerates which AI tools and extensions are present on each developer machine, feeding the organization-wide AI footprint.
- **Defend** — real-time prompt-injection scanning of AI tool outputs, plus installation and healing of the defender hooks when Desktop Guard isn't present.
- **Honest scoping:** the JetBrains plugin is post-hoc audit today (transcript monitoring, status, offline queue); pre-send enforcement there is on the roadmap — stated plainly rather than implied.

Infrastructure Agent & SDKs

A Go agent that governs **server-side, CI/CD, and hosted-workload** AI traffic — deliberately **without a MITM proxy**, so it is never a latency tax or a single point of failure in the request path.

- **Transcript mode** — tails the session logs AI tools already write on VMs and build hosts (Claude Code, Codex, Gemini, Aider, Cursor), normalizes each turn, and reports it.
- **Tap mode** — accepts externally captured request/response pairs from network taps, sidecars, and log forwarders — strictly observe-only.
- **eBPF egress observer** *(Linux, optional)* — classifies outbound connections against the AI-provider catalog at the kernel tracepoint level, metadata only.
- **In-process SDK governance** — the **Python and Node SDKs** and the **AWS Lambda layer** wrap OpenAI/Anthropic/Bedrock-style calls with `evaluate()` and `wrap()`; this is the one server-side path that can **block in-line**, under your code's control, with configurable fail-open.
- **AWS Bedrock, fully covered** — a one-line SDK wrapper across `invoke_model` / `converse` and streams; an ingest worker that decodes Bedrock invocation logs (for managed Bedrock Agents no SDK can reach); Terraform to stand it up; and translation of Whiteout policies into **native AWS Bedrock Guardrails**.
- **Providers recognized:** OpenAI · Anthropic · Google (Vertex / AI Studio) · AWS Bedrock · Cohere · Mistral · HuggingFace · Together · Fireworks · Perplexity · Groq · DeepSeek · OpenRouter — plus egress-level classification of Azure OpenAI, Microsoft Copilot, Grok, Poe, AI21, Replicate, Cerebras, SambaNova, and more.
- **Fleet operations** — registration, 30-second heartbeats, atomic policy refresh, enforce/warn/monitor policy modes (in-line blocking applies on the SDK path; the agent itself observes), offline/air-gapped operation with local policy bundles, and liveness alerting when an agent goes dark.

Mobile Governance

AI governance for managed **iOS and Android** — **audit-only by design**, because mobile operating systems prohibit pre-send gating, and honesty about that is a feature.

- Device enrollment with beacon liveness, batched AI-app discovery and usage reporting, and a governed judge endpoint that vets captured content and logs verdicts without blocking. On-device content capture is on the roadmap; today the mobile surface is device inventory, AI-app discovery, and policy.
- Per-organization and per-group AI-app block policies, optionally **pushed into the MDM** (e.g., Intune configuration profiles) — Whiteout authors the policy; the MDM enforces it.
- A mobile admin console: coverage stats, device inventory with staleness detection, alerts, activity feed, and analytics down to users-at-risk.
- Broad consumer-AI app catalog: Gemini, Perplexity, Copilot, Poe, Character.AI, Jasper, Copy.ai, Replika, and more.

Prompt-Injection Defense & Agentic AI Security

Agentic coding tools execute shell commands, edit files, and read whatever their tools return. That makes **prompt injection** — malicious instructions smuggled into tool output, web content, or repository files — a first-class enterprise threat: an injected instruction can turn a developer's own AI agent into an exfiltration channel.

Whiteout AI ships a layered defense, centrally installed and tamper-protected by Desktop Guard (or by the IDE extension when Desktop Guard isn't present). The same managed hooks run under **Claude Code, Cursor, and OpenAI Codex** — one pattern library, one enforcement contract, every governed coding agent.

Three interception points

1. **Prompt entry** (`UserPromptSubmit`) — scans what the user submits to the agent.
2. **Before tool execution** (`PreToolUse`) — the enforcement point: risky tool calls can be stopped *before* they run.
3. **After tool output** (`PostToolUse`) — scans what came back, warning on injected instructions before the model acts on them.

Six detection categories

A curated pattern library — extending recognized open-source injection research with Whiteout-specific rules — covering: **instruction override** ("ignore previous instructions"), **role-playing jailbreaks** (DAN, developer-mode personas), **encoding & obfuscation** (base64, hex, zero-width characters, homoglyphs, leetspeak), **context manipulation** (fake system/admin messages, false authority, system-prompt extraction), **data exfiltration** (credentials paired with outbound vectors — `curl` + secret, secrets into git, SQL extraction of credential columns), and **policy bypass** (attempts to disable governance or kill the monitoring process).

Tuned to be believed

The defense is deliberately **warn-first**: routine developer operations (reading an `.env` locally, a force-push, test mocks) warn rather than block, because an over-blocking defender gets disabled — and a disabled defender protects no one. Exactly one category **hard-blocks unconditionally: defender self-protection**. Any command that mutates the defense's own scripts, patterns, or configuration — or kills the governance process — is stopped outright, because the moment an agent tries to disable its own guardrails is precisely the moment it may be the compromised actor.

Tamper resistance

- Hook scripts and patterns are installed centrally, locked read-only, re-hashed every 60 seconds against source, and **surgically repaired** on drift.
- A settings watcher restores removed hook registrations — touching only Whiteout's entries, never the developer's own configuration.
- Hooks authenticate at runtime via short-lived tokens from a local broker — **no credentials stored on disk**.
- A sanctioned **assessment mode** relaxes exfiltration detections for legitimate security testing — while self-protection stays hard-blocking even then.

MCP Governance: One Governed Front Door to Corporate Data

AI assistants are most useful when they can touch business systems — and most dangerous. Whiteout AI governs this in both directions.

Blocking the ungoverned paths

Vendor-native connectors (ChatGPT's and Claude's own integrations) and their OAuth grants are **blocked at the endpoint** for disallowed sources — the browser extension disables connector rows and stops grants before a token is minted; Desktop Guard enforces the same posture in native apps. Employees aren't left to decide which AI may read the corporate drive.

Blocking new grants isn't enough on day one: Whiteout also **discovers the connector grants that already exist** — including which were authorized by personal rather than corporate accounts — pins vendor-verified OAuth client identities, and gives administrators **central revocation** that takes effect across every device, with resolved findings tracked to closure.

The governed alternative: Whiteout as the AI connector

Whiteout is itself an **MCP server and an OpenAPI connector** — a single governed gateway that Claude Desktop, Claude Code, Cursor, ChatGPT (Custom GPTs / Enterprise), and Gemini plug into. Same governance, two protocols, one code path.

23 governed integrations across the systems where corporate data actually lives:

Category	Integrations
Project & issue tracking	Jira · Confluence · GitHub · GitLab · Linear · Asana · Trello
Communication	Slack · Microsoft Teams · Zoom · Intercom
Email & calendar	Gmail · Google Calendar · Outlook Mail · Outlook Calendar
Documents & storage	Google Drive · SharePoint · OneDrive · Box · Dropbox · Notion
CRM & business	Salesforce · HubSpot

Identity-true access

- **Three auth schemes** — personal bearer tokens, a full **OAuth 2.1 authorization server** (dynamic client registration, PKCE, refresh rotation — users click "Connect" and operate as themselves), and first-party platform JWTs. One revocation kills access everywhere.
- **Per-user source ACLs** — every read is served with the *querying user's own* credential, so the source system's permissions decide what each user sees. Whiteout never grants access the source wouldn't.
- **Zero-click provisioning** — a one-time Google Workspace domain-wide-delegation grant, and a one-time Microsoft 365 tenant admin consent, roll the connector out org-wide with **no per-user OAuth screens** — while preserving per-user ACL fidelity on every read.
- **Dedicated connector policy with group scoping** — connector reads are governed by an explicit, auditable policy set (not whichever groups an admin belongs to), with exempt-group carve-outs: Finance may retrieve finance documents while everyone else stays blocked. Exemptions fail closed and every exercised exemption is audited.

Outbound vetting — the part that actually stops leaks

Access control decides *whether* an assistant may call Jira. **Field-level response vetting** decides *what content comes back*:

- Every tool response is classified against the policy library **before any model sees it**: blocked fields are nulled; existence-classified items are **removed entirely**, so the assistant never learns the document exists; and an annotation explains what was withheld.
- A two-stage pipeline keeps it fast — a ~50 ms metadata match, then LLM classification with a hard timeout — and it **fails closed** on errors and oversized content.
- Documents are deep-classified against the entire policy library on connect and kept current by continuous sync (provider change-cursors within minutes, webhooks within ~a second); a policy toggle re-derives verdicts on already-classified documents **with no re-scan**; and anything without a fresh stamp is re-vetted inline before it is served.
- Every allowed, blocked, and redacted call is fully audited — user, tool, integration, outcome, latency, sanitized parameters — and every block/omit emits a real-time **SOC event**.

Administrators review every classification in a Documents view — with per-document override (always available / always hidden / policy-decided) as a governed, audited escape hatch that never silently erases the classification.

Identity, Access & Device Trust

- **8 identity providers over OIDC** — Microsoft Entra ID, Okta, Google Workspace, OneLogin, Ping Identity, JumpCloud, Auth0, and Generic OIDC — with guided setup and connection testing.
- **Directory sync done right** — just-in-time provisioning, group-membership mapping, auto-deprovisioning, full group lifecycle (renames propagate; deleted IdP groups pause their mapping visibly instead of failing silently), and **selective onboarding** so a pilot can govern fifty people before it governs five thousand.
- **SCIM 2.0** — standards-compliant real-time provisioning, plus a read-only **SCIM verifier** that detects missed pushes — a silent skipped deprovision is a security incident, not a sync hiccup.
- **Role-based access control** — admin / user / **read-only auditor**, enforced server-side (auditors are admitted only on safe read methods — a real boundary, not grayed-out buttons). Admin authority is scoped to the organization; there is deliberately no cross-tenant superadmin.
- **Universal login** — Desktop Guard acts as a loopback identity broker: sign in once on the device and the browser extension, IDE plugins, and admin app silently receive delegated, consented, device-bound tokens. Admin sign-in to the console is intentionally **never** brokered.
- **Hardware-anchored device identity** — tokens bind to stable hardware identifiers that survive reinstalls, so the machines view groups every client by physical device and a re-imaged laptop re-enrolls itself.
- **Zero-touch MDM enrollment** — per-device, device-attested enrollment tokens deployed through Intune or Jamf mean clients authenticate on first launch with no end-user interaction — and the flow is a strict no-op on unmanaged machines.
- **MDM integration** — Intune (full, via Microsoft Graph) and Jamf adapters; a curated AI-app catalog plus 30+ AI service domains turn raw device inventories into "who runs which AI tool"; device-trust signals (compliance, encryption, supervision) inform access; and AI-app blocking policies authored in Whiteout push into the MDM for fleet enforcement.

Audit, Visibility & SOC Integration

A defensible system of record

- **Complete interaction audit** — every prompt, file, tool call, and decision is logged with user, group, model, surface, verdict, and full override metadata. Violations are recorded as **structured findings** — the exact policy, data class, and severity as they stood at decision time — so analytics survive later policy edits.
- **Both sides of the exchange** — every prompt-capture surface also captures the **assistant's response** (read from the DOM, accessibility tree, or on-disk transcript — never via MITM), because an audit record that omits what the AI sent back is half an investigation.
- **Token metering & cost visibility** — every interaction carries token counts, the specific model, and estimated cost; real provider figures where the pathway exposes them, clearly-marked estimates elsewhere — never conflated.
- **Admin config-change audit trail** — every administrative action (policy edits, role changes, integration changes, token mints, even report exports) writes an **append-only** audit row with actor, IP, and sanitized old→new values, browsable and exportable. There are deliberately no edit or delete endpoints. Who changed the governance platform itself is an auditor's first question; it has a first-class answer.
- **Prompt Review** — a cross-surface, server-filtered review console (desktop, browser, IDE, mobile, internal) with full-text search, token badges, captured responses, and one-click **CSV / PDF export**.

SOC/SIEM delivery

- **Six destination types** — HMAC-signed webhooks, **Splunk** (HEC), **Microsoft Sentinel** (DCR/DCE), and **Elasticsearch** with active delivery; **IBM QRadar** (syslog) and **Amazon S3** (JSONL/Parquet) configurable and connection-tested with delivery formatters rolling out.
- **Privacy profiles** — per-destination transforms deliver full, redacted, or hash-only events with pass-through / strip / tokenize PII modes; not every destination is cleared for raw prompt content.
- **Resilient batching** — buffered delivery with size/age flushing, failure tracking, and auto-disable — high-volume prompt traffic never hammers SIEM ingest one event at a time.

Shadow-AI discovery

You cannot govern what you cannot see. Whiteout maintains a live, organization-wide **AI Footprint**:

- **Two axes** — what AI is *installed* (desktop apps, browser/IDE extensions, CLIs, SDK dependencies, local LLM runtimes, model files, MCP servers) and what is *actually used* (prompt logs, transcripts, network egress) — folded into one inventory with per-tool drill-down to exact devices and users.
- **Open-world detection** — beyond fixed signatures: local model servers are found by probing loopback listeners on any port, unknown AI SDKs by package-keyword scanning — surfacing genuinely new AI the day it appears, not the day a catalog updates.
- **Coverage envelope** — an honest panel reporting how much of the estate discovery can currently see, so "no findings" is never confused with "no visibility."
- **Governed-vs-shadow split** — ungoverned tools become severity-scored findings with a review workflow and SOC deep-links; an admin can promote a discovered unknown into the catalog once and have it recognized fleet-wide with no client redeploy.

- **Usage, people & spend views** — AI Activity (which tools, by whom, on what surface), People (per-user usage, data-class exposure, shadow-AI use, and a transparent risk score), Token Usage (organizational consumption and estimated spend by model), and an **AI Connector dashboard** (who pulls what corporate data through the governed connector, allowed vs. blocked, by integration and calling client) — all from the same audit stores, so the numbers never disagree.

Deployment, Operations & Platform Security

- **Deployment models** — fully self-hosted (including the compliance engine on your GPUs), Whiteout-managed with a self-hosted engine, or managed SaaS. The data-residency promise holds in every model: authoritative evaluation can always run on infrastructure you control. Air-gapped operation is supported at the infrastructure-agent layer.
- **Multi-tenant isolation** — org/group-scoped policy and data with centralized tenant-isolation guards on every read and write.
- **Hardened software supply chain** — desktop and extension clients update over signed channels; the Windows updater double-verifies SHA-512 **and** Authenticode pinned to the Groovy Security signing identity, re-checked at install time — a compromised CDN cannot push a malicious build.
- **Enterprise distribution** — VS Code & JetBrains marketplaces, notarized macOS DMG, per-user Windows installers (NSIS and MSI), Docker/Helm for the agent, Python/Node SDKs, a Lambda layer, and MDM-driven mass deployment.
- **Abuse protection** — token-bucket rate limiting on sensitive endpoints and streaming-concurrency controls protect the engine under load.
- **Supportability without data access** — self-hosted deployments stay supportable without weakening the residency promise: application logs are **content-free by contract** (a CI gate verifies no prompt or document content can reach them), a customer-run bundle collects diagnostics for support, and remote access exists only as a **dormant, customer-controlled break-glass** the vendor cannot open alone.
- **Fail-safe by design** — distinct visual states for approved, blocked, and degraded; graceful degradation with user notification; and the explicit, per-organization fail-open/fail-closed choice described above.

Regulatory Alignment

Whiteout AI's policy library maps to the frameworks enterprises are audited against, and its audit trail is built to be the evidence.

Framework	How Whiteout AI helps
HIPAA	5 PHI policies covering patient identifiers, diagnoses, and records; minimum-necessary enforcement at the prompt boundary; complete audit trail of every health-data interaction.
GDPR	8 policies for personal and special-category data; data minimization enforced before external processing; accountability via immutable audit; support for data-subject investigations.
SOX	Internal controls over financial data at the AI boundary; MNPI and unreleased-forecast blocking; append-only audit of access and administrative change.
PCI-DSS	Cardholder-data blocking before external AI; access control and complete tracking of payment-data exposure.
SOC 2 / ISO 27001	Security-domain policies (secrets, keys, credentials, infrastructure); exportable evidence of control operation; admin config-change audit.

Industry use cases

- **Healthcare** — clinicians use AI for templates, letters, and research while patient names, MRNs, and diagnoses are blocked in real time; aggregate and operational queries flow freely; every interaction is audit-ready.
- **Financial services** — unreleased earnings, forecasts, and M&A detail cannot leave to external AI; public-market analysis remains untouched; insider-risk teams get a real-time SOC feed.
- **Technology** — developers get AI assistance without exposing credentials, keys, or proprietary algorithms; coding agents are governed at the prompt, the tool call, and the transcript; the IDE fleet is inventoried for shadow AI.
- **Legal** — attorney-client communications and litigation strategy are blocked from external AI; general legal research proceeds; privilege is protected at the boundary where waiver happens.

Conclusion

Enterprises do not get to choose whether employees use AI. They choose whether that use is visible, governed, and defensible — or invisible, ungoverned, and discoverable only in the breach report.

Whiteout AI makes the governed path the productive path: real-time semantic policy enforcement with 96.8% corrected accuracy on a public 100,000-prompt benchmark and a 99.9% pass rate on everyday prompts; coverage across the browser, desktop, IDE, infrastructure, mobile, and the AI connectors in between; prompt-injection defense for the agentic tools now writing your code; a governed MCP gateway for the data your assistants read; and an audit trail built to satisfy the regulator who asks *prove it*.

See it on your own traffic. Deploy in Audit-Only mode and discover your organization's real AI footprint in days — then turn on enforcement policy by policy.

Schedule a consultation: groovysec.com/demo

*Whiteout AI is built by **Groovy Security**. The compliance benchmark dataset is public at huggingface.co/datasets/ShmalexFlow/enterprise-ai-prompt-compliance-100k under Apache 2.0, and the accompanying technical report (TR-2026-09) is at groovysec.com. Benchmark figures: 100,000 prompts, deployed engine, September 2026 — 96.53% raw, 96.78% corrected after adjudication of residual misses against the deployed rule text. Platform capabilities described*

reflect the shipped product as of September 2026; roadmap items are identified as such. *© 2026 Groovy Security. All product names and trademarks are the property of their respective owners.*